Cas Operació Far · Nivell 1 (cas guiat)

MÒDUL: Optativa de Ciberseguretat **GRUP:** DAW1

NOM I COGNOMS: Komalpreet Kaur **DATA:** 09/11/2026

Nota: totes les dades del cas són fictícies (empresa NovaTerra Logística SL). He treballat només amb els fitxers de la carpeta cas_Operacio_Far.

Pregunta 1 · Qui hi ha darrere de l'empresa? (sense FLAG)

He obert la pàgina Equip (web/equip.html) i he copiat cada persona amb el seu càrrec i correu:



web/equip.html — pàgina Equip

Nom	Càrrec	Correu

Marina Casals Roig	Directora tècnica (CTO)	marina.casals@novaterra-logistica.example
Jordi Puig Serra	Administrador de sistemes	jordi.puig@novaterra-logistica.example
Anna Vidal Mas	Recursos humans	anna.vidal@novaterra-logistica.example
Pau Ribas Soler	Comptabilitat	pau.ribas@novaterra-logistica.example

Resposta: El patró dels correus és nom.cognom@novaterra-logistica.example (el primer nom i el primer cognom, en minúscula, separats per un punt). Sí, si sé el nom d'una persona nova de l'empresa puc endevinar el seu correu. Per exemple, si entra en Marc Soler, el seu correu seria marc.soler@novaterra-logistica.example. Això és un risc, perquè un atacant pot escriure a qualsevol treballador sense buscar gaire.

Pregunta 2 · El que no es veu a simple vista (F1 + F2)

He mirat el codi font de la pàgina Equip amb Ctrl+U i hi he trobat un comentari amagat (<!-- … -->):

Line wrap

```
<!DOCTYPE html>
<html lang="ca"><head><meta charset="utf-8"><title>Equip · NovaTerra Logística</title>
<link rel="stylesheet" href="css/style.css"></head><body>
<header><h1>NovaTerra Logística</h1>
<nav><a href="index.html">Inici</a><a href="equip.html">Equip</a><a href="blog.html">Notícies</a><a href="contacte.html">Contacte</a></nav></header>
<main>
<div class="card"><h2>Direcció i equip</h2>
<img src="img/foto_equip.jpg" alt="Foto de l'equip a l'esmorzar d'empresa">
<ul>
<li><strong>Marina Casals Roig</strong> · Directora tècnica (CTO) · marina.casals@novaterra-logistica.example</li>
<li><strong>Jordi Puig Serra</strong> · Administrador de sistemes · jordi.puig@novaterra-logistica.example</li>
<li><strong>Anna Vidal Mas</strong> · Recursos humans · anna.vidal@novaterra-logistica.example</li>
<li><strong>Pau Ribas Soler</strong> · Comptabilitat · pau.ribas@novaterra-logistica.example</li>
</ul></div>
<!-- TODO Jordi: treure el compte de proves test_nt abans de passar a produccio.
     Nota interna: FLAG{els_comentaris_tambe_son_publics} -->
</main>
<footer>© 2026 NovaTerra Logística SL · Empresa fictícia per a ús educatiu</footer></body></html>
```

Codi font de equip.html — comentari ocult amb la FLAG F1

Després he obert web/robots.txt:

```
root@vm:~/cas_Operacio_Far$
$ cat web/robots.txt

User-agent: *
Disallow: /intranet/
Disallow: /backup/
Disallow: /admin-proves/
# Nota: FLAG{robots_txt_no_es_un_mur}
```

web/robots.txt

Flag: `F1: FLAG{els_comentaris_tambe_son_publics}`

Flag: `F2: FLAG{robots_txt_no_es_un_mur}`

Resposta: Al codi font hi ha un comentari que els programadors es van deixar: diu que encara hi ha un compte de proves (test_nt) que s'ha de treure abans de passar a producció. Això és informació sensible, perquè un atacant ja sap que existeix un usuari de proves. Al robots.txt hi ha carpetes «amagades» (/intranet/, /backup/, /admin-proves/). El robots.txt no protegeix res: només demana als buscadors que no les indexin, però qualsevol persona les pot visitar. De fet és com un mapa de les carpetes privades.

Pregunta 3 · La foto parla (F3)

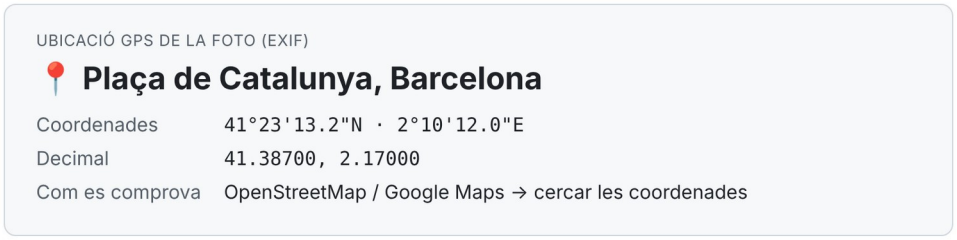
He mirat les metadades (EXIF) de la foto de l'equip:

```
root@vm:~/cas_Operacio_Far$
$ exiftool web/img/foto_equip.jpg

Make                :  Samsung
Camera Model Name   :  SM-G991B
Software            :  G991BXXU5CVJ1
Artist              :  Marina Casals Roig
Image Description   :  Foto del grup a la terrassa del cafe
Date/Time Original  :  2026:10:15 09:42:11
User Comment        :  Esmorzar d'equip dijous. FLAG{les_fotos_amaguen_coordenades}
GPS Latitude        :  41 deg 23' 13.20" N
GPS Longitude       :   2 deg 10' 12.00" E
GPS Position        :  41 deg 23' 13.20" N, 2 deg 10' 12.00" E
```

Metadades EXIF de web/img/foto_equip.jpg

Les coordenades GPS porten a aquest lloc:



Coordenades 41°23'13.2"N 2°10'12.0"E → Plaça de Catalunya, Barcelona

Flag: `F3: FLAG{les_fotos_amaguen_coordenades}`

Resposta: La foto la va fer Marina Casals amb un mòbil Samsung SM-G991B el 15/10/2026 a les 09:42. Les coordenades GPS (41°23'13.2"N, 2°10'12.0"E) són a la Plaça de Catalunya de Barcelona, just on hi ha l'oficina. La FLAG estava amagada al camp «UserComment». Això vol dir que una foto pujada a internet pot dir qui, quan i on, sense que la persona se n'adoni.

Pregunta 4 · El document que parla més del compte (F4 + F5)

He mirat les metadades del PDF i després he seleccionat tot el text (Ctrl+A) per llegir el que estava tapat amb barres negres:

```
root@vm:~/cas_Operacio_Far$
$ pdfinfo documents/Pla_estrategic_2026.pdf

Title:           Pla estratègic 2026
Subject:         Original a \\\\SRV-NT-FILES\\Direccio\\Pla_2026.docx
Keywords:        FLAG{metadades_de_documents}
Author:          mcasals
Creator:         Microsoft Word 2019
Producer:        Microsoft: Print To PDF

$ pdftotext documents/Pla_estrategic_2026.pdf -   (selecciona i copia tot el text, surt el que estava tapat)

NovaTerra Logística · Pla estratègic 2026
Document de treball intern. Confidencial.


1. Objectius 2026
- Migrar el ERP a LogiCore v3.2 (15 de novembre).
- Obrir un tercer magatzem a la zona nord.


2. Proveïdors clau
Proveïdor de transport: TransIberia SL
Proveïdor cloud: CloudCat Hosting · cuenta cliente NT-48211
Contacte tècnic del proveïdor:            suport@cloudcat.example · 93 111 22 33


3. Accessos temporals durant la migració
Compte de servei de la migració:             svc_migracio
Contrasenya inicial (canviar després):              Migr@cio2026!




Nota interna: FLAG{redactar_no_es_tapar_amb_negre}
```

Metadades i text recuperat de documents/Pla_estrategic_2026.pdf

Flag: `F4: FLAG{metadades_de_documents}`

Flag: `F5: FLAG{redactar_no_es_tapar_amb_negre}`

Resposta: A les metadades es veu l'autor (mcasals), el programa (Microsoft Word 2019) i fins i tot la ruta interna on es guarda l'original (\\SRV-NT-FILES\Direccio\Pla_2026.docx). La FLAG F4 era a les «Keywords». A dins del document hi havia text tapat amb barres negres, però només estava amagat a la vista: en seleccionar-lo i copiar-lo apareix el compte de servei de la migració (svc_migracio) i la contrasenya (Migr@cio2026!). És un problema greu, perquè una barra negra a sobre no esborra el text: segueix dins del fitxer. Per censurar bé cal esborrar el text de veritat (per exemple, exportant el PDF ja aplanat o eliminant el contingut, no pintant-hi a sobre).

Pregunta 5 · DNS i domini (F6)

He llegit el fitxer dades/whois_dns.txt:

```
root@vm:~/cas_Operacio_Far$
$ cat dades/whois_dns.txt

# Dades fictícies de novaterra-logistica.example (format simplificat)

Domain Name: NOVATERRA-LOGISTICA.EXAMPLE
Registrar: CatDomains Registrar SL
Creation Date: 2015-04-02
Registrant Organization: NovaTerra Logística SL
Registrant Email: jordi.puig@novaterra-logistica.example
Admin Name: Jordi Puig Serra
Name Server: ns1.cloudcat.example
Name Server: ns2.cloudcat.example

;; DNS records
novaterra-logistica.example.        A       198.51.100.20
www.novaterra-logistica.example.    CNAME   novaterra-logistica.example.
mail.novaterra-logistica.example.   A       198.51.100.25
intranet.novaterra-logistica.example. A     198.51.100.30
test.novaterra-logistica.example.   A       198.51.100.31
novaterra-logistica.example.        MX 10   mail.novaterra-logistica.example.
novaterra-logistica.example.        TXT     "v=spf1 ip4:198.51.100.25 ~all"
_dev.novaterra-logistica.example.   TXT     "FLAG{el_dns_te_pistes_amagades}"
```

dades/whois_dns.txt

Flag: `F6: FLAG{el_dns_te_pistes_amagades}`

Resposta: Als registres DNS es veu el correu de l'administrador (jordi.puig@...), els servidors de noms (ns1/ns2.cloudcat.example) i diversos subdominis: www, mail, intranet i test. Els més interessants per a un atacant són intranet (zona privada de l'empresa) i test (servidor de proves, que sol estar pitjor protegit i amb dades reals). La FLAG estava en un registre TXT del subdomini amagat _dev. Lliçó: el DNS és públic i pot donar pistes sobre la infraestructura interna.

Pregunta 6 · Informe d'exposició (sense FLAG)

Resposta: Informe per al client (NovaTerra Logística):

- 1) Contrasenya al PDF (documents/Pla_estrategic_2026.pdf): el compte svc_migracio i la seva contrasenya Migr@cio2026! es poden llegir malgrat la barra negra. És el risc més greu: accés directe.
- 2) Compte de proves test_nt (comentari a equip.html): un usuari oblidat és una porta d'entrada fàcil.
- 3) Carpetes privades exposades al robots.txt (/intranet/, /backup/, /admin-proves/): diuen a l'atacant on mirar.
- 4) Correus previsibles (equip.html): el patró nom.cognom permet escriure a tothom (phishing).
- 5) Geolocalització de la foto (EXIF de foto_equip.jpg): revela l'adreça exacta de l'oficina.
- Recomanació urgent: canviar immediatament la contrasenya svc_migracio i tornar a generar el PDF sense el text tapat, perquè una contrasenya filtrada dona accés directe als sistemes durant la migració.